K8s

Pod Intro

Create a pod

> Pods are the smallest deployable units of computing that you can create and manage in Kubernetes.

https://kubernetes.io/docs/concepts/worklo

Create a pod called of image `my-pod` `nginx:alpine`

先寫一個 pod.yaml

```yaml
apiVersion: v1
kind: Pod
metadata:
  name: my-pod
spec:
  containers:
  - name: nginx
    image: nginx:alpine
```

再用指令執行

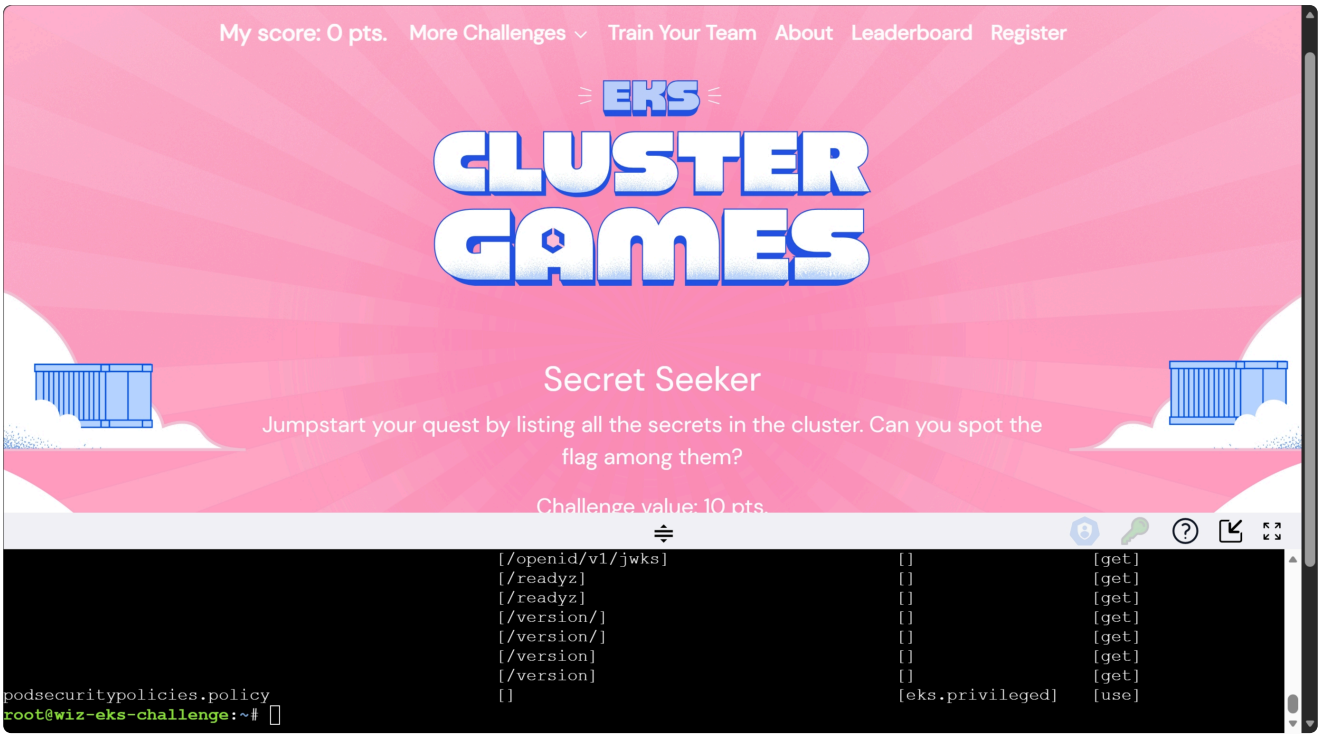
```
k apply -f pod.yml
```

接下來是刪除

```
k delete pod my-pod
```

EKS challenge

1

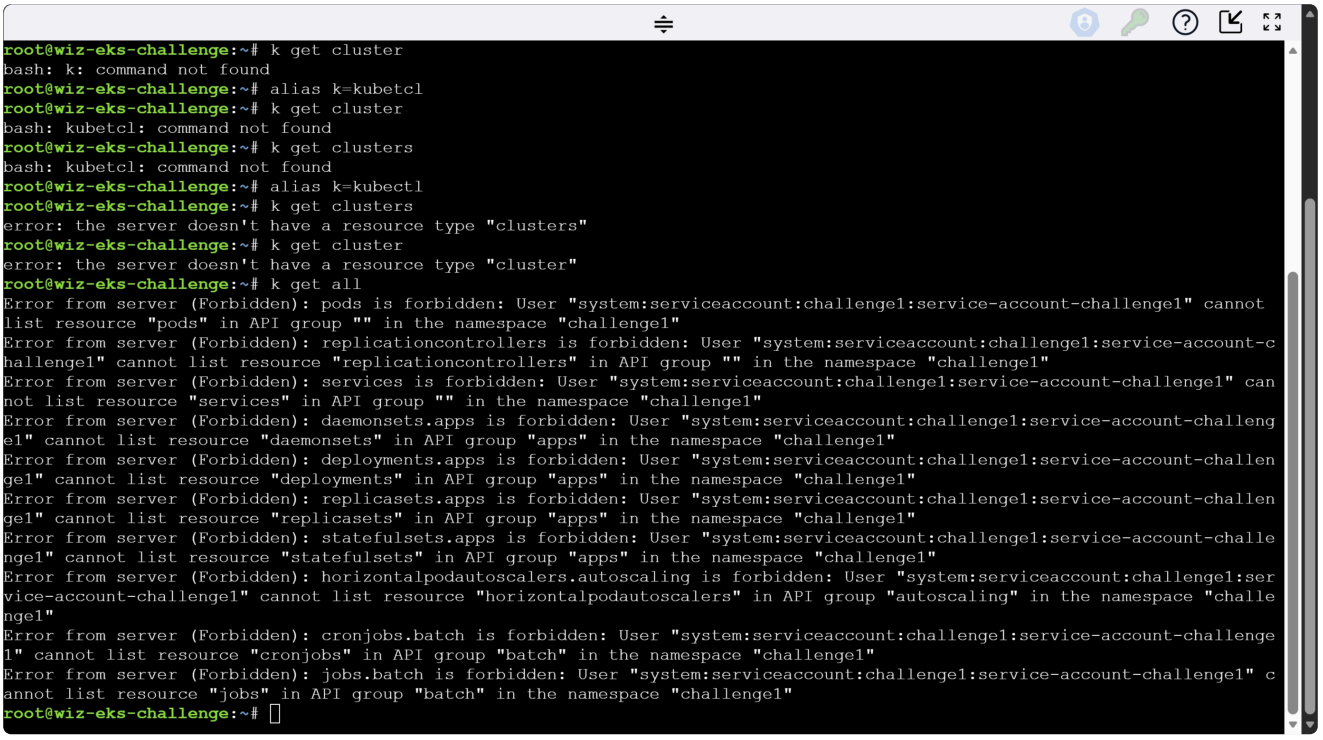


題外話，為了方便，設定了一個別名，就不用每次都打 kubectl 了

題目要我列出 cluster，所以我先查了一下指令

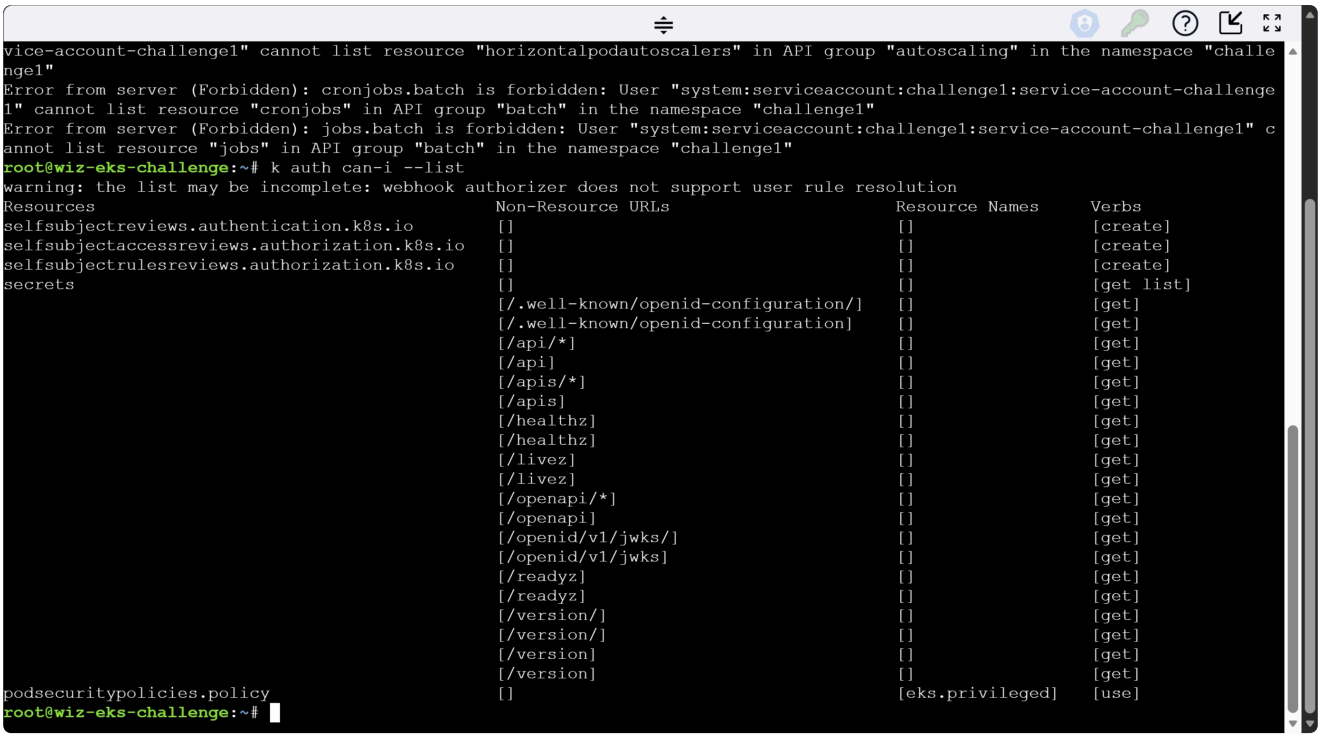
```
k get all
```

發現我現在好像沒有權限



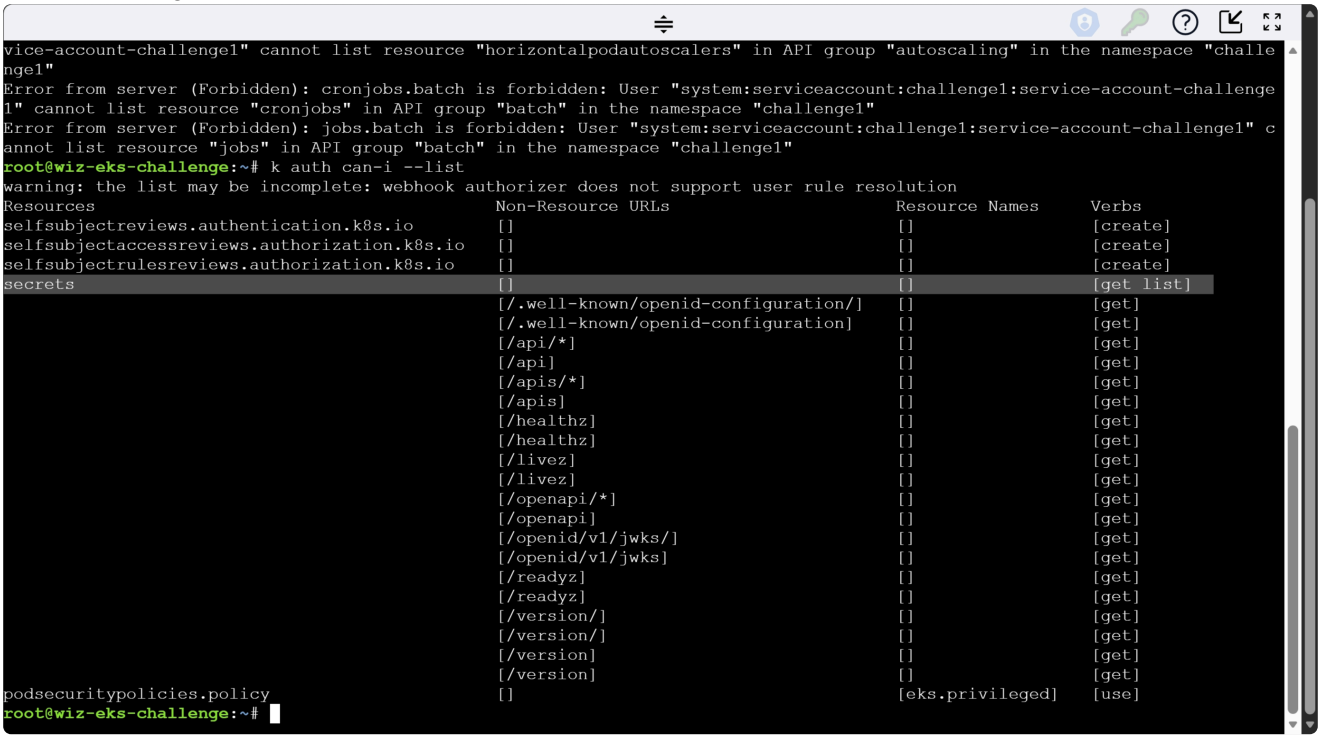
所以就把權限列出來看看

```
k auth can-i --list
```



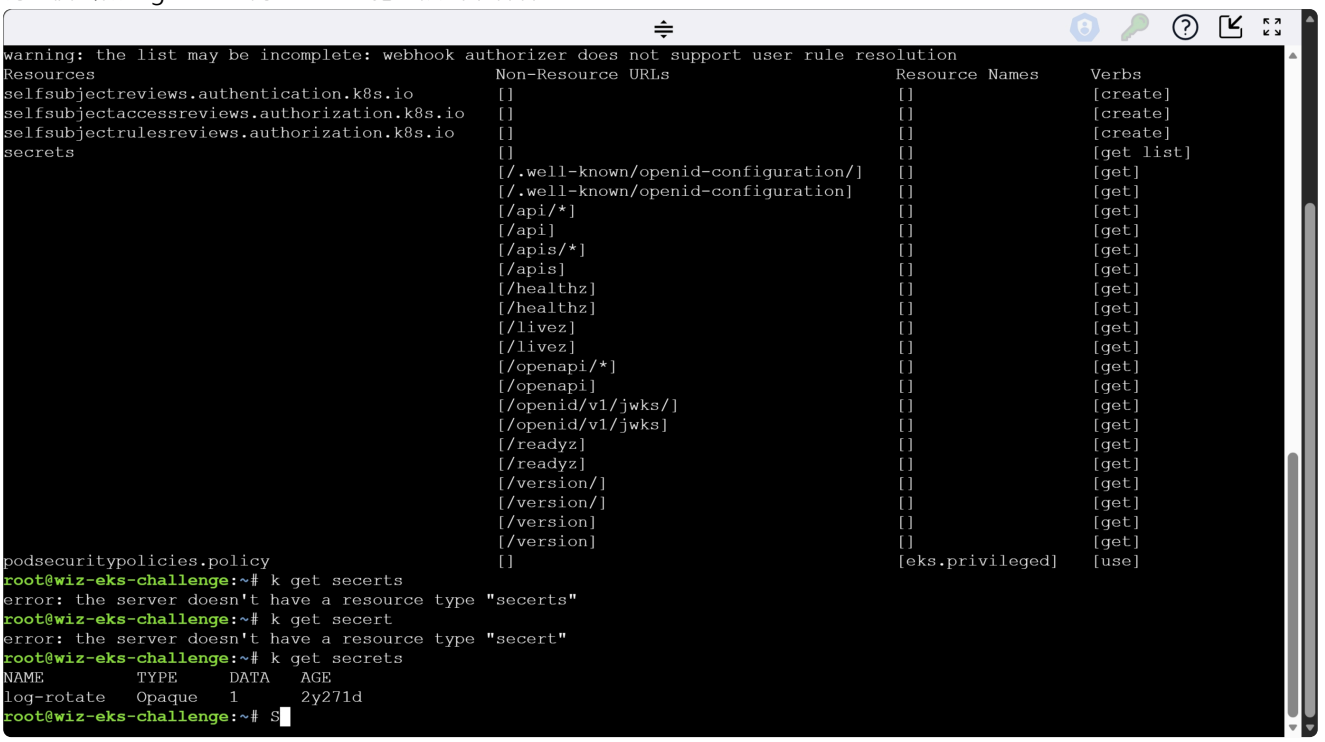
```
vice-account-challenge1" cannot list resource "horizontalpodautoscalers" in API group "autoscaling" in the namespace "challe
nge1"
Error from server (Forbidden): cronjobs.batch is forbidden: User "system:serviceaccount:challenge1:service-account-challenge
1" cannot list resource "cronjobs" in API group "batch" in the namespace "challenge1"
Error from server (Forbidden): jobs.batch is forbidden: User "system:serviceaccount:challenge1:service-account-challenge1" c
annot list resource "jobs" in API group "batch" in the namespace "challenge1"
root@wiz-eks-challenge:~# k auth can-i --list
warning: the list may be incomplete: webhook authorizer does not support user rule resolution
Resources                                       Non-Resource URLs                      Resource Names     Verbs
selfsubjectreviews.authentication.k8s.io        []                                     []                 [create]
selfsubjectaccessreviews.authorization.k8s.io   []                                     []                 [create]
selfsubjectrulesreviews.authorization.k8s.io    []                                     []                 [create]
secrets                                         []                                     []                 [get list]
                                                [/.well-known/openid-configuration/]   []                 [get]
                                                [/.well-known/openid-configuration]    []                 [get]
                                                [/api/*]                               []                 [get]
                                                [/api]                                 []                 [get]
                                                [/apis/*]                              []                 [get]
                                                [/apis]                                []                 [get]
                                                [/healthz]                             []                 [get]
                                                [/healthz]                             []                 [get]
                                                [/livez]                               []                 [get]
                                                [/livez]                               []                 [get]
                                                [/openapi/*]                           []                 [get]
                                                [/openapi]                             []                 [get]
                                                [/openid/v1/jwks/]                     []                 [get]
                                                [/openid/v1/jwks]                      []                 [get]
                                                [/readyz]                              []                 [get]
                                                [/readyz]                              []                 [get]
                                                [/version/]                            []                 [get]
                                                [/version/]                            []                 [get]
                                                [/version]                             []                 [get]
                                                [/version]                             []                 [get]
podsecuritypolicies.policy                      []                                     [eks.privileged]   [use]
root@wiz-eks-challenge:~#
```

發現 secrets 是 get list，代表我可以列出 secrets



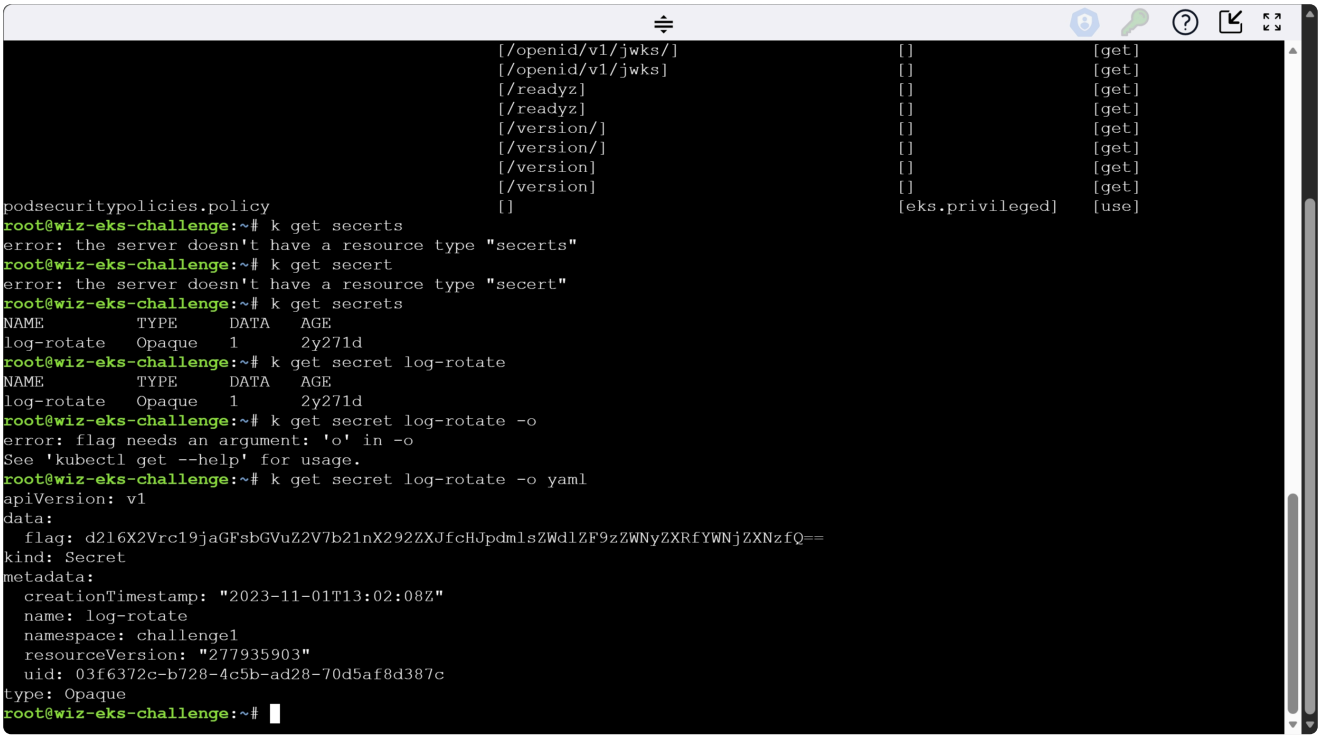
```
vice-account-challenge1" cannot list resource "horizontalpodautoscalers" in API group "autoscaling" in the namespace "challe
nge1"
Error from server (Forbidden): cronjobs.batch is forbidden: User "system:serviceaccount:challenge1:service-account-challenge
1" cannot list resource "cronjobs" in API group "batch" in the namespace "challenge1"
Error from server (Forbidden): jobs.batch is forbidden: User "system:serviceaccount:challenge1:service-account-challenge1" c
annot list resource "jobs" in API group "batch" in the namespace "challenge1"
root@wiz-eks-challenge:~# k auth can-i --list
warning: the list may be incomplete: webhook authorizer does not support user rule resolution
Resources                                       Non-Resource URLs                      Resource Names     Verbs
selfsubjectreviews.authentication.k8s.io        []                                     []                 [create]
selfsubjectaccessreviews.authorization.k8s.io   []                                     []                 [create]
selfsubjectrulesreviews.authorization.k8s.io    []                                     []                 [create]
secrets                                         []                                     []                 [get list]
                                                [/.well-known/openid-configuration/]   []                 [get]
                                                [/.well-known/openid-configuration]    []                 [get]
                                                [/api/*]                               []                 [get]
                                                [/api]                                 []                 [get]
                                                [/apis/*]                              []                 [get]
                                                [/apis]                                []                 [get]
                                                [/healthz]                             []                 [get]
                                                [/healthz]                             []                 [get]
                                                [/livez]                               []                 [get]
                                                [/livez]                               []                 [get]
                                                [/openapi/*]                           []                 [get]
                                                [/openapi]                             []                 [get]
                                                [/openid/v1/jwks/]                     []                 [get]
                                                [/openid/v1/jwks]                      []                 [get]
                                                [/readyz]                              []                 [get]
                                                [/readyz]                              []                 [get]
                                                [/version/]                            []                 [get]
                                                [/version/]                            []                 [get]
                                                [/version]                             []                 [get]
                                                [/version]                             []                 [get]
podsecuritypolicies.policy                      []                                     [eks.privileged]   [use]
root@wiz-eks-challenge:~#
```

有一個叫做 log-rotate 的 secret，把它讀出來看看

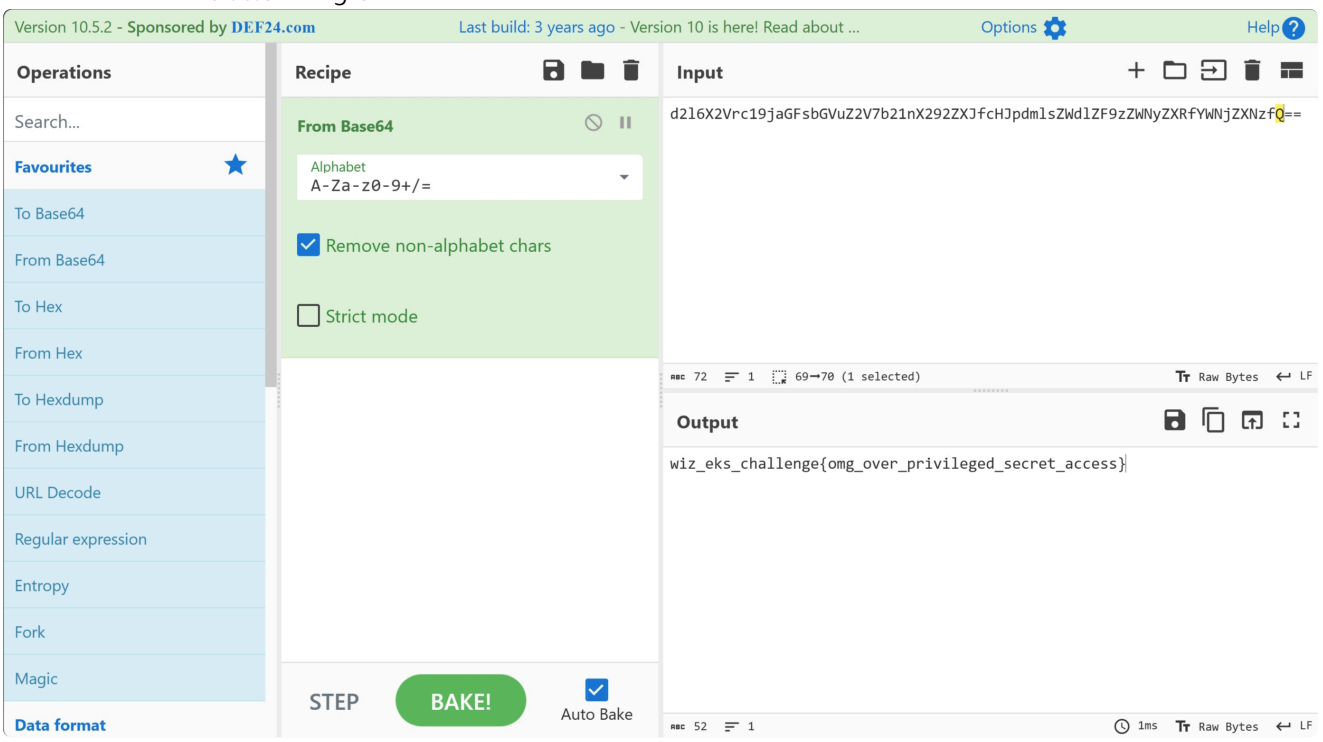


指令如下

```
k get secret log-rotate -o yaml
```

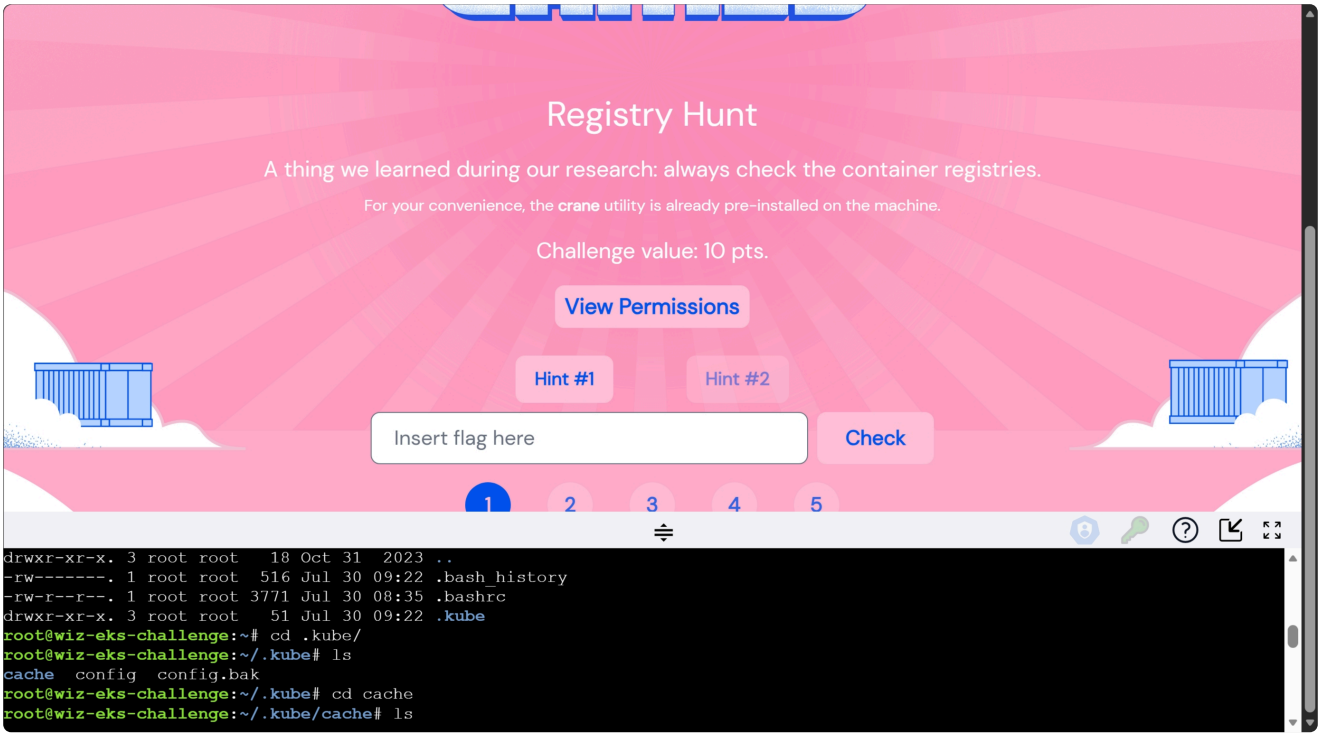


base64 decode 一下就得到 flag 了

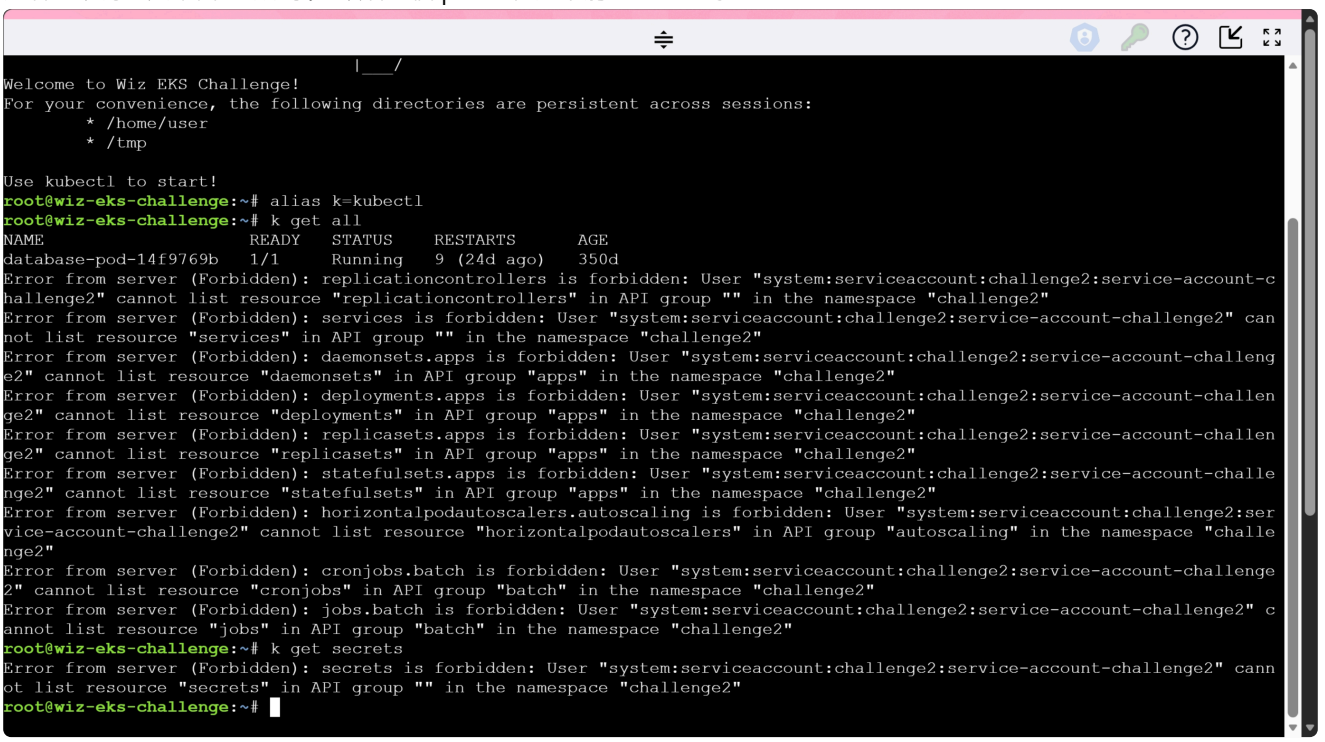


2

題目：



先看一下有甚麼東西，發現我可以看一個 pod，但是不能碰 secret 了



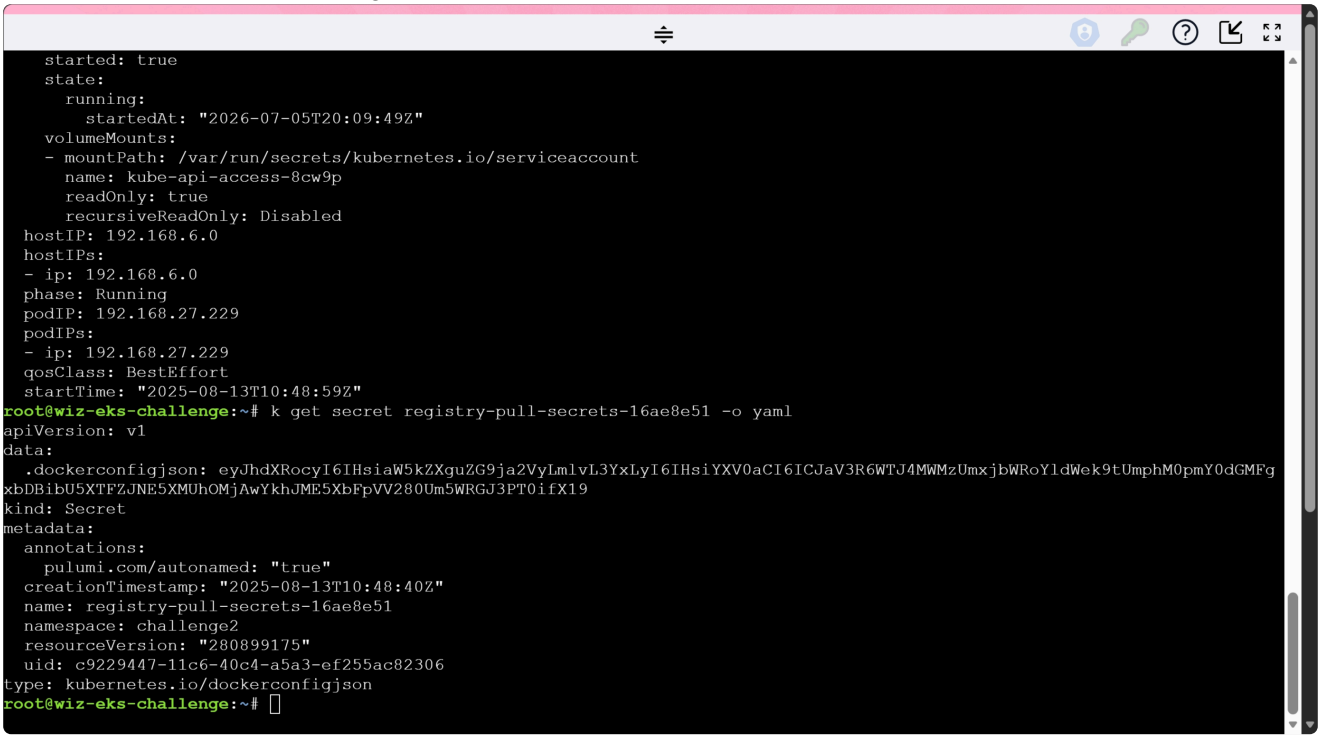
所以我可以看它的 yaml 裡面寫了甚麼。它裡面有一個 container 叫做 my-container，用的是 eksclustergames/base_ext_image 這個 image；然後看到眼睛快脫窗，才看到它有一個 imagePullSecrets，一看就很 secret。查了一下它是怎麼運作的，發現它就是拉取 image 用的憑證，所以我可以用這個憑證來拉我想看的非公開 image

```yaml
apiVersion: v1
kind: Pod
metadata:
  annotations:
    pulumi.com/autonamed: "true"
  creationTimestamp: "2025-08-13T10:48:59Z"
  generation: 1
  name: database-pod-14f9769b
  namespace: challenge2
  resourceVersion: "463369723"
  uid: e1c6b56d-15d5-491d-9cc8-fa6d739b62c2
spec:
  containers:
  - image: eksclustergames/base_ext_image
    imagePullPolicy: Always
    name: my-container
    resources: {}
    terminationMessagePath: /dev/termination-log
    terminationMessagePolicy: File
    volumeMounts:
    - mountPath: /var/run/secrets/kubernetes.io/serviceaccount
      name: kube-api-access-8cw9p
      readOnly: true
  dnsPolicy: ClusterFirst
  enableServiceLinks: true
  imagePullSecrets:
  - name: registry-pull-secrets-16ae8e51
  nodeName: ip-192-168-6-0.us-west-1.compute.internal
  preemptionPolicy: PreemptLowerPriority
  priority: 0
  restartPolicy: Always
  schedulerName: default-scheduler
  securityContext: {}
  serviceAccount: default
  serviceAccountName: default
  terminationGracePeriodSeconds: 30
```

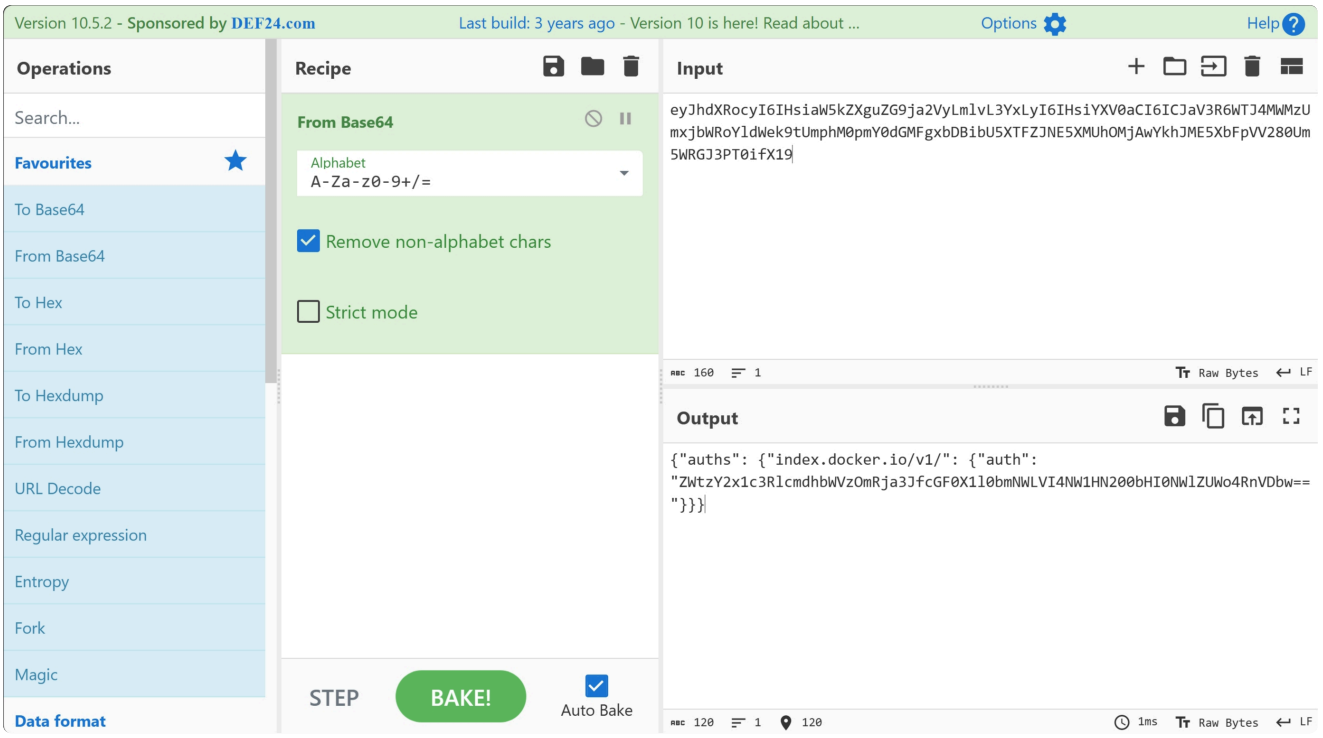
```
  tolerations:
  - effect: NoExecute
    key: node.kubernetes.io/not-ready
    operator: Exists
    tolerationSeconds: 300
  - effect: NoExecute
    key: node.kubernetes.io/unreachable
    operator: Exists
    tolerationSeconds: 300
  volumes:
  - name: kube-api-access-8cw9p
    projected:
      defaultMode: 420
      sources:
      - serviceAccountToken:
          expirationSeconds: 3607
          path: token
      - configMap:
          items:
          - key: ca.crt
            path: ca.crt
          name: kube-root-ca.crt
      - downwardAPI:
          items:
          - fieldRef:
              apiVersion: v1
              fieldPath: metadata.namespace
            path: namespace
status:
  conditions:
  - lastProbeTime: null
    lastTransitionTime: "2025-08-13T10:49:05Z"
    status: "True"
    type: PodReadyToStartContainers
  - lastProbeTime: null
    lastTransitionTime: "2025-08-13T10:48:59Z"
    status: "True"
    type: Initialized
  - lastProbeTime: null
    lastTransitionTime: "2026-07-05T20:09:50Z"
    status: "True"
    type: Ready
  - lastProbeTime: null
    lastTransitionTime: "2026-07-05T20:09:50Z"
    status: "True"
    type: ContainersReady
  - lastProbeTime: null
    lastTransitionTime: "2025-08-13T10:48:59Z"
    status: "True"
    type: PodScheduled
  containerStatuses:
  - containerID: containerd://76db4e06b8787bf5eb2a36f4038bb16f643c7cfee8d50778fcec3e2749c02b18
    image: docker.io/eksclustergames/base_ext_image:latest
    imageID:
docker.io/eksclustergames/base_ext_image@sha256:dc7972c9abff930285186786ba21cdf44a401e91ece2dddd4b487
a6028fb3804
    lastState:
      terminated:
        containerID: containerd://3a837362aa2b4d383989fb6c7c42306fa735180684b5dd6e3566dfa891019754
        exitCode: 0
        finishedAt: "2026-07-05T20:09:49Z"
        reason: Completed
        startedAt: "2026-05-30T13:47:32Z"
    name: my-container
    ready: true
    resources: {}
```

```
    restartCount: 9
    started: true
    state:
      running:
        startedAt: "2026-07-05T20:09:49Z"
    volumeMounts:
    - mountPath: /var/run/secrets/kubernetes.io/serviceaccount
      name: kube-api-access-8cw9p
      readOnly: true
      recursiveReadOnly: Disabled
  hostIP: 192.168.6.0
  hostIPs:
  - ip: 192.168.6.0
  phase: Running
  podIP: 192.168.27.229
  podIPs:
  - ip: 192.168.27.229
  qosClass: BestEffort
  startTime: "2025-08-13T10:48:59Z"
```

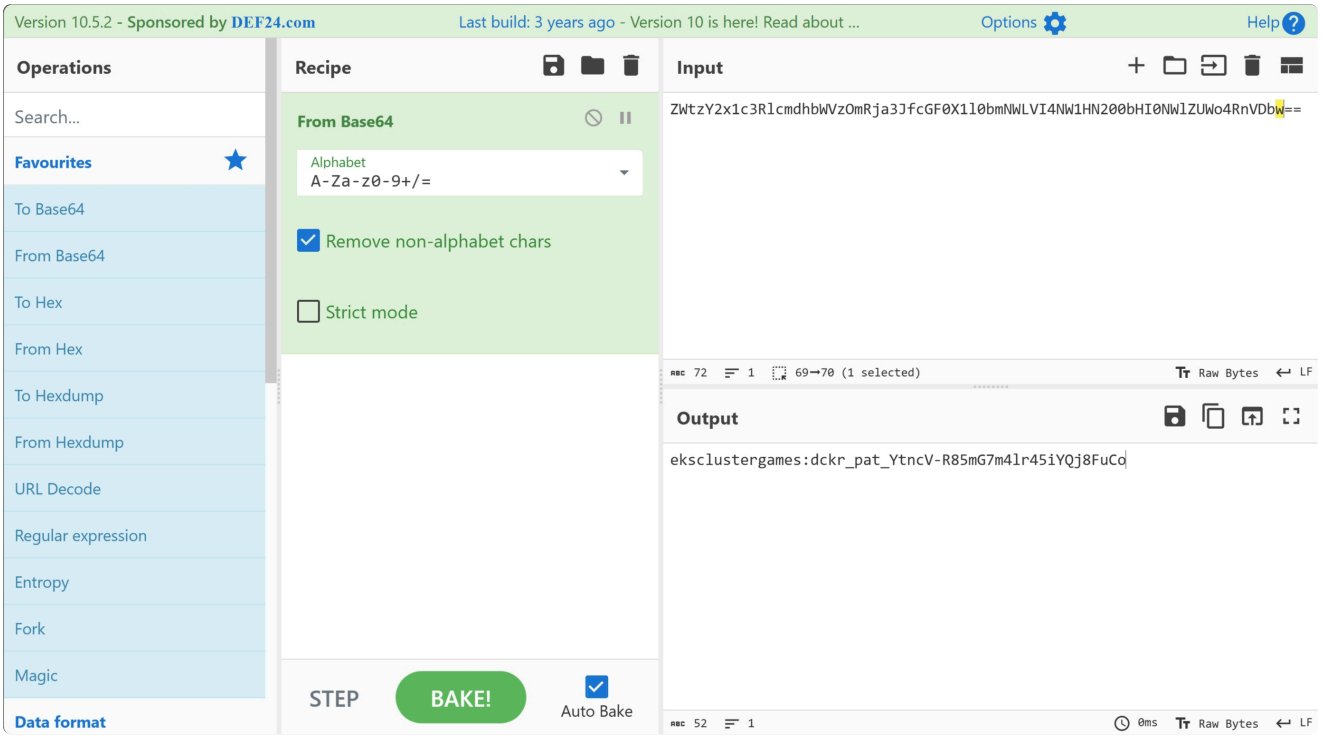
所以知道憑證名稱之後，應該可以 get 吧？



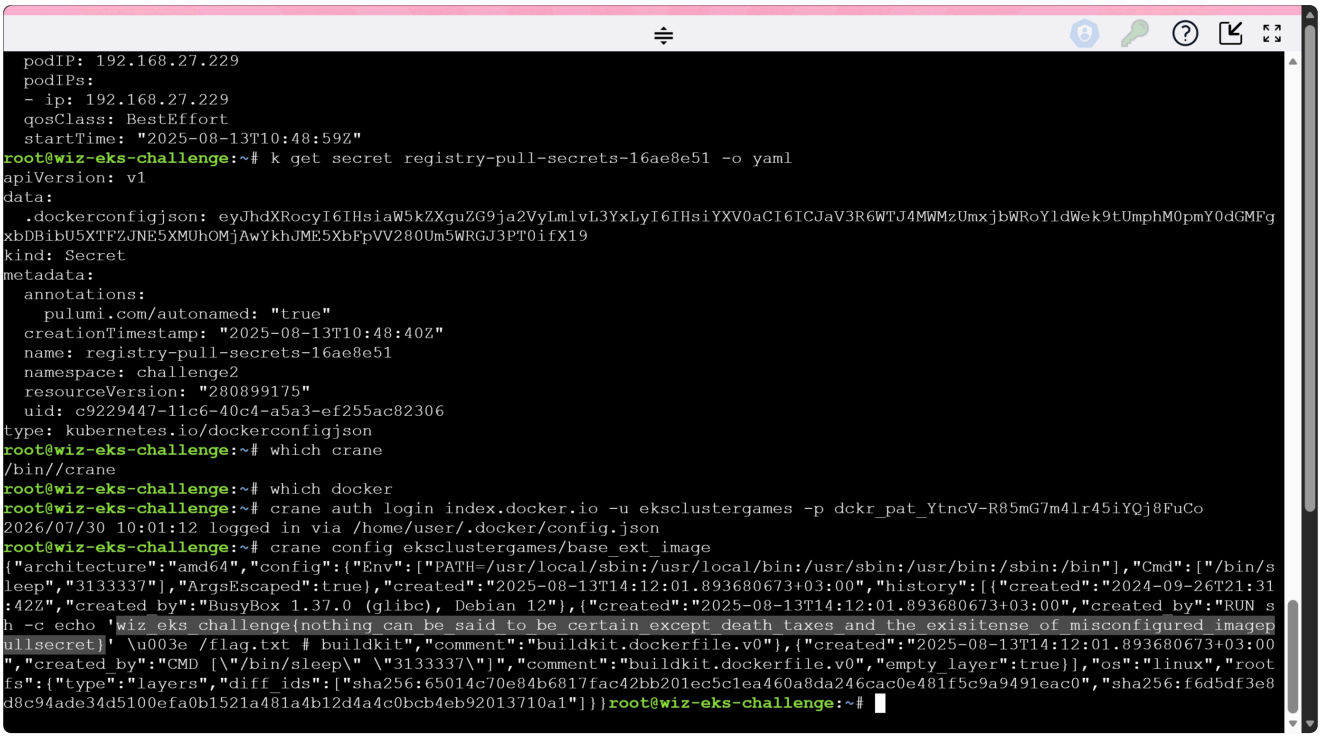
把這串拿去 base64 decode



看到裡面還有一串 base64，繼續 decode，這串應該就是 auth



所以接下來就是熟悉的環節，把 image 抓下來跑起來看裡面有甚麼。但 vm 裡面沒有 docker，所以改用 crane 看 config 裡面有甚麼，然後就發現 flag 了



小結

今天先把 K8s 基本操作走一遍（`k apply` 建 pod、`k delete` 刪掉），接著開始做 EKS Cluster Games。

- **第 1 題**：`k get all` 沒權限，改用 `k auth can-i --list` 看自己能做什麼，發現 secrets 可以 get / list，讀出 `log-rotate` 再 base64 decode 就拿到 flag。
- **第 2 題**：不能碰 secret，但看得到 pod。翻它的 yaml 發現 `imagePullSecrets`，那是拉 image 用的憑證，讀出來 decode 兩層拿到 registry auth；vm 裡沒有 docker，改用 crane 看 image config 就找到 flag。

參考資料

- EKS Cluster Games
- Announcing the EKS Cluster Games | Wiz Blog
- Pods | Kubernetes
- Secrets | Kubernetes
- Using RBAC Authorization | Kubernetes（`kubectl auth can-i`）
- Pull an Image from a Private Registry | Kubernetes（imagePullSecrets / `.dockerconfigjson`）
- crane - google/go-containerregistry